TechSecure Solutions: NIST CSF 2.0 Maturity Assessment

Fictional organisation | Self-directed training project | Martin Paul Searle | October 2026

This is a training exercise. TechSecure Solutions, its staff, systems and the evidence described below are invented to practise applying the NIST Cybersecurity Framework. Scores are illustrative judgements made against simulated evidence, not findings from a real organisation.

1. Summary

TechSecure Solutions is a fictional US-based provider of cloud services to small businesses, with about 120 staff. This assessment scores its cybersecurity programme against all six functions of NIST CSF 2.0 (Govern, Identify, Protect, Detect, Respond, Recover) and sets a target profile.

Overall current maturity: 2.3 out of 5. Target: 3.5. Gap: 1.2.

TechSecure's technical protection (Protect, 2.8) is its strongest area, while governance, detection and incident response are weakest. Supply chain risk management is the lowest-scoring category (1) and, given that TechSecure relies on cloud and third-party providers, is the highest priority gap.

Function	Current	Target	Gap
Govern (GV)	2.2	3.7	1.5
Identify (ID)	2.3	3.7	1.4
Protect (PR)	2.8	3.6	0.8
Detect (DE)	2.0	3.5	1.5
Respond (RS)	2.0	3.3	1.3
Recover (RC)	2.5	3.5	1.0
Overall	**2.3**	**3.5**	**1.2**

2. Scope and method

Scope: TechSecure's corporate IT, cloud hosting platform, customer data and employee processes.

Framework: NIST Cybersecurity Framework 2.0 (February 2024), scored at category level. The six functions are used, including Govern, which was added in version 2.0.

Maturity scale (1 to 5). This is a simple scale used for this exercise. It is separate from the CSF's own Implementation Tiers.

1. **Initial:** ad hoc, undocumented, depends on individuals
2. **Developing:** some practices exist but are informal or inconsistent
3. **Defined:** documented, approved and generally followed
4. **Managed:** measured, monitored and reviewed regularly
5. **Optimised:** continuously improved using metrics and lessons learned

Evidence: simulated document review and staff interviews, described in each category below.

Target profile: set at 3 or 4 per category, based on a small cloud provider handling customer data. A target of 5 everywhere would be unrealistic and costly for a firm this size.

Limitations: the evidence is fictional, so the scores show how the method is applied, not real security posture. No technical testing was performed.

3. Findings by function

Govern (GV): average 2.2

- **GV.OC Organisational Context: 3 (target 4).** *Evidence:* the business strategy names customer data protection as a priority, and customer contracts list security and privacy obligations. *Reasoning:* the context is documented and understood, so a 3. It does not yet feed into risk decisions or reporting, which keeps it from a 4.
- **GV.RM Risk Management Strategy: 2 (target 4).** *Evidence:* risk is discussed in management meetings, but there is no risk appetite statement or agreed method. *Reasoning:* practices exist but are informal. A 4 requires a defined appetite and regular review.
- **GV.RR Roles and Responsibilities: 2 (target 4).** *Evidence:* the IT manager acts as security lead, with no formal role description or board-level owner. *Reasoning:* accountability depends on one person, so a 2.

- **GV.PO Policy: 3 (target 4).** *Evidence:* an information security policy exists and was approved, but is reviewed only when something changes. *Reasoning:* documented and approved, which meets a 3. A scheduled review would move it to a 4.
- **GV.OV Oversight: 2 (target 3).** *Evidence:* leadership receives ad hoc updates on incidents but no regular security reporting. *Reasoning:* oversight happens informally.
- **GV.SC Supply Chain Risk Management: 1 (target 3).** *Evidence:* no supplier inventory by risk, no security clauses in most supplier contracts, and no due diligence before onboarding vendors. *Reasoning:* a cloud provider depends heavily on third parties, so the absence of any process is the largest governance gap.

Identify (ID): average 2.3

- **ID.AM Asset Management: 3 (target 4).** *Evidence:* a spreadsheet inventory of hardware and cloud services is kept, but software and data assets are incomplete. *Reasoning:* documented and used, but coverage is partial.
- **ID.RA Risk Assessment: 2 (target 4).** *Evidence:* a risk assessment was done once, two years ago, and has not been repeated. Vulnerability scans run irregularly. *Reasoning:* the practice exists but is not repeated, so a 2.
- **ID.IM Improvement: 2 (target 3).** *Evidence:* lessons from incidents are discussed informally but not recorded or tracked to completion. *Reasoning:* improvement happens, but without evidence of follow-through.

Protect (PR): average 2.8

- **PR.AA Identity Management, Authentication and Access Control: 3 (target 4).** *Evidence:* multi-factor authentication is enforced for administrators and cloud consoles, with role-based access, but access reviews are not scheduled. *Reasoning:* strong controls that are defined and followed, with no review cycle to reach a 4.
- **PR.AT Awareness and Training: 2 (target 3).** *Evidence:* staff receive one induction session, with no refresher or phishing exercises. *Reasoning:* training exists but is a one-off.
- **PR.DS Data Security: 3 (target 4).** *Evidence:* customer data is encrypted at rest and in transit, and backups are encrypted. Data classification is informal. *Reasoning:* the key technical controls are in place, but classification and retention rules are not formal.
- **PR.PS Platform Security: 3 (target 4).** *Evidence:* servers are built from hardened images and patched monthly. Exceptions are not tracked. *Reasoning:* a defined routine, without measurement.
- **PR.IR Technology Infrastructure Resilience: 3 (target 3).** *Evidence:* the platform runs across two availability zones with documented failover. *Reasoning:* meets the target, so no gap.

Detect (DE): average 2.0

- **DE.CM Continuous Monitoring: 2 (target 4).** *Evidence:* cloud logs are collected but not centrally correlated, and nobody reviews alerts outside office hours. *Reasoning:* logs exist, but monitoring is not systematic. For a 24/7 service this is a priority gap.
- **DE.AE Adverse Event Analysis: 2 (target 3).** *Evidence:* events are investigated when noticed, with no triage criteria or severity levels. *Reasoning:* analysis is reactive and inconsistent.

Respond (RS): average 2.0

- **RS.MA Incident Management: 2 (target 4).** *Evidence:* an incident response plan was drafted but never tested, and roles are unclear. *Reasoning:* a plan that has never been exercised cannot be assumed to work.
- **RS.AN Incident Analysis: 2 (target 3).** *Evidence:* root causes are sometimes recorded, with no standard template. *Reasoning:* informal.
- **RS.CO Incident Response Reporting and Communication: 2 (target 3).** *Evidence:* no defined process for notifying customers or regulators, which matters given breach notification duties. *Reasoning:* communication depends on who is available at the time.
- **RS.MI Incident Mitigation: 2 (target 3).** *Evidence:* containment steps are known by the technical team but not documented. *Reasoning:* knowledge sits with individuals.

Recover (RC): average 2.5

- **RC.RP Incident Recovery Plan Execution: 3 (target 4).** *Evidence:* backups are tested twice a year and restore times are documented. *Reasoning:* defined and tested, but recovery targets are not tied to customer commitments.
- **RC.CO Incident Recovery Communication: 2 (target 3).** *Evidence:* no template or owner for updating customers during an outage. *Reasoning:* informal and dependent on individuals.

4. Priority gaps and recommendations

Priorities are ranked by size of gap and risk to the business.

1. **Supply chain risk (GV.SC, 1 to 3).** Build a supplier inventory, rank suppliers by risk, add security clauses to contracts, and require due diligence for new vendors. *Why first:* a failure at a cloud or software supplier directly affects customers.
2. **Risk management (GV.RM and ID.RA, 2 to 4).** Define a risk appetite, adopt a risk register, and repeat the risk assessment annually. *Why:* every other control decision depends on a current view of risk.

3. **Monitoring and detection (DE.CM and DE.AE, 2 to 4 and 3).** Centralise logs, define alert triage, and arrange out-of-hours coverage. *Why:* TechSecure is a 24/7 service, and late detection increases damage and notification obligations.
4. **Roles and accountability (GV.RR, 2 to 4).** Appoint a named security owner with a role description and a board sponsor.
5. **Incident response (RS.MA, 2 to 4).** Run a tabletop exercise, assign roles, and add customer and regulator notification steps.
6. **Awareness training (PR.AT, 2 to 3).** Add annual training and phishing simulations.

5. Proposed roadmap

- **0 to 3 months:** appoint a security owner, build the supplier inventory, draft the risk appetite, run the first incident tabletop exercise.
- **3 to 6 months:** repeat the risk assessment, add supplier contract clauses, introduce alert triage and a severity scale.
- **6 to 12 months:** centralised logging and out-of-hours monitoring, scheduled access reviews, annual training, and a reassessment against this target profile.

6. Reflections

- A maturity score is a judgement, not a measurement. Different assessors could reasonably score some categories one point higher or lower, so the written reasoning matters more than the number.
- Fictional evidence limits how much can be concluded. A real assessment would test evidence by sampling records, checking configurations and interviewing more than one person per area.
- Mapping findings to Govern in CSF 2.0 shows how risk ownership and supply chain risk now sit at the centre of the framework rather than at the edges.